

Task 1: Define your class project

Elias Leander Branstötter & Laura Golubov

→ Project Idea and description:

Webbased solution to buy concert/event tickets → Webpage (Online Shop)

Different types of music/events, promoting the idea of quality time spent, maybe even some advantages going with friends. The Webpage should be easy to handle and self-explanatory < “less is more”

→ Requirements of data handling:

**) we have tested already some requirements in Visual Studio Code with GitHubCopilot and the following requirements of data handling were delivered by AI*

Purpose and Scope

The application processes personal, booking, payment, and ticket data to allow users to search events, reserve seats, purchase tickets, and manage their orders.

The system shall process only data that is necessary for:

- User registration and authentication
- Event and seat availability management
- Shopping cart and temporary seat reservations
- Payment processing
- Ticket generation and validation
- Order history and customer support
- Legal, accounting, and security obligations

The application shall comply with the applicable data protection regulations, particularly the GDPR/DSGVO, and applicable PCI-DSS requirements.

2. Categories of Data

2.1 User Account Data

The system may store:

- First name and last name
- Email address
- Password hash
- Telephone number, if required
- Billing address

- Shipping address, if physical documents are supported
- Account creation date
- Last login date
- Account status
- User preferences and consent records

Passwords shall never be stored in plain text. They shall be stored using a secure, modern password hashing algorithm such as Argon2id or bcrypt.

2.2 Event Data

The system shall store:

- Event name
- Artist or performer
- Event category
- Venue name
- Venue address
- City
- Event date and time
- Ticket categories and price tiers
- Seating plan
- Seat identifiers
- Seat availability
- Event status
- Event images and descriptions

2.3 Seat and Reservation Data

For every seat, the system shall be able to identify:

- Event ID
- Seat ID
- Seating area or price tier
- Current status:
 - Available
 - Temporarily reserved
 - Sold
 - Blocked
 - Cancelled
- Reservation owner
- Reservation creation time
- Reservation expiration time
- Purchase association, if sold

A seat shall not be sold to more than one customer. Seat availability changes shall be processed atomically and consistently.

2.4 Cart Data

The shopping cart shall contain:

- User ID or anonymous session ID
- Event ID
- Selected seat IDs
- Ticket quantity
- Ticket prices
- Cart creation time
- Reservation expiration time
- Cart status

Temporary reservations shall automatically expire after ten minutes if checkout is not completed.

2.5 Payment Data

The application shall store only the minimum payment information required for transaction processing and order administration.

The system shall not store:

- Full credit card numbers
- Card security codes/CVV
- Unencrypted payment credentials
- PayPal passwords
- Full bank account credentials

Payment processing shall be delegated to a PCI-DSS-compliant payment provider.

The application may store:

- Payment provider name
- Provider transaction ID
- Payment status
- Payment method type
- Masked payment identifier, for example last four card digits
- Amount and currency
- Transaction timestamp
- Refund status
- Payment failure reason, if available

2.6 Order Data

Each order shall include:

- Unique order ID
- User ID
- Purchased event
- Purchased seats
- Ticket category
- Quantity
- Unit price
- Total amount
- Currency
- Payment status
- Order status
- Order creation date
- Cancellation or refund date
- Invoice data
- Ticket identifiers

2.7 Digital Ticket Data

Each digital ticket shall include:

- Unique ticket ID
- Associated order ID
- Event ID
- Seat ID
- Ticket holder, if applicable
- QR code payload
- Ticket status:
 - Valid
 - Used
 - Cancelled
 - Refunded
- Issue date
- Scan date and venue entrance information

The QR code shall contain a signed or otherwise verifiable token and shall not expose unnecessary personal information.

2.8 Technical and Security Data

The system may process:

- IP address
- Login timestamps
- Device and browser information
- Session identifiers
- Authentication logs
- Audit logs
- Failed login attempts
- Security alerts
- Consent records

Technical data shall be used only for security, fraud prevention, system operation, and legally justified analytics.

3. Data Collection Requirements

1. The system shall inform users about the purpose of data collection before collecting personal data.
 2. Required and optional data fields shall be clearly distinguished.
 3. The system shall not require unnecessary personal information.
 4. Forms shall validate input both client-side and server-side.
 5. Invalid, incomplete, or suspicious input shall be rejected with a clear error message.
 6. Email addresses shall be validated before account activation or ticket delivery.
 7. The system shall prevent duplicate accounts where the same verified email address is already registered.
 8. Data entered into search fields shall not be stored as personal data unless required for a clearly explained purpose.
 9. Consent shall be recorded with:
 - User ID
 - Consent type
 - Consent text or version
 - Timestamp
 - Consent status
 10. Withdrawal of consent shall be supported wherever processing is based on consent.
-

4. Data Storage Requirements

4.1 Database Consistency

The database shall enforce:

- Unique user email addresses
- Unique order IDs
- Unique ticket IDs
- Unique QR code tokens
- Valid event-seat relationships
- Valid order-ticket relationships
- Valid payment-order relationships

The system shall use database transactions for:

- Seat reservation
- Seat release
- Order creation
- Payment confirmation
- Ticket generation
- Refund or cancellation processing

4.2 Seat Reservation Consistency

When a user selects a seat:

1. The system shall check whether the seat is available.
2. The system shall reserve the seat atomically.
3. The system shall store the reservation expiration time.
4. The system shall reject concurrent reservations for the same seat.
5. Expired reservations shall be released automatically.
6. A payment confirmation shall convert the reservation into a sold seat.
7. A failed or abandoned checkout shall release the seat.

The system shall support high-traffic operation without double booking.

4.3 Data Separation

The system should logically separate:

- Identity data
- Payment transaction data
- Event and inventory data
- Order data
- Security logs
- Marketing consent data

Access to each data category shall be restricted according to business need.

5. Data Security Requirements

5.1 Encryption

1. All communication shall use HTTPS with TLS.
2. Passwords shall be hashed using Argon2id or bcrypt.
3. Sensitive data stored in databases or backups shall be encrypted where appropriate.
4. Encryption keys shall be stored separately from application data.
5. Payment data shall be handled by a certified payment provider.
6. Cookies containing sessions or authentication tokens shall use:
 - Secure
 - HttpOnly
 - Appropriate SameSite settings

5.2 Authentication and Authorization

1. Users shall authenticate using email and password or a supported secure identity provider.
2. The system shall support password reset using time-limited tokens.
3. Sessions shall expire after a defined period of inactivity.
4. Users shall only access their own account, payment references, orders, and tickets.
5. Administrative users shall have role-based permissions.
6. Sensitive administrative actions shall be logged.
7. Multi-factor authentication should be supported for administrators and optionally for customers.
8. Repeated failed login attempts shall trigger rate limiting or temporary account protection.

5.3 Application Security

The application shall protect against:

- SQL injection
- Cross-site scripting
- Cross-site request forgery
- Session fixation
- Brute-force attacks
- Credential stuffing
- Unauthorized ticket reuse
- Manipulation of prices or order totals
- Seat reservation race conditions
- Insecure direct object references

Prices, seat status, payment status, and order totals shall always be verified on the server.

6. Data Access Requirements

The system shall implement role-based access control.

Customer

A customer may:

- View and edit their own profile
- View their own order history
- View and download their own tickets
- Manage saved payment references
- Delete their account
- Manage communication preferences

Event Administrator

An event administrator may:

- Create and update events
- Manage venues and seating plans
- View event inventory
- View event-related orders
- Process approved cancellations or refunds

An event administrator shall not automatically be able to access full payment details or unrelated customer data.

Support User

A support user may:

- Search orders using authorized identifiers
- View payment status
- Assist with ticket delivery
- Handle cancellations and refunds according to permissions

System Administrator

A system administrator may:

- Manage system configuration
- Manage users and roles
- View security logs

- Manage backups and infrastructure

Administrative access shall be logged and reviewed.

7. Data Retention Requirements

The system shall define and document retention periods.

Recommended retention rules:

Data type	Retention requirement
Active account data	Until account deletion or required legal retention
Temporary seat reservations	Maximum 10 minutes
Completed order data	According to applicable accounting and tax laws
Payment transaction references	According to payment provider and legal requirements
Digital tickets	Until the event and applicable dispute period have ended
Used ticket scan records	According to event security and legal requirements
Failed login logs	Limited period, for example 90 days
Security audit logs	According to security policy, for example 12 months

Marketing consent records	Until withdrawal plus legally required evidence period
---------------------------	--

Abandoned carts	Short-lived; automatically deleted after expiration
-----------------	---

Support requests	According to customer service retention policy
------------------	--

Expired or no longer necessary data shall be deleted or anonymized automatically.

8. User Rights

The application shall support the following GDPR/DSGVO rights:

1. Right of access
2. Right to rectification
3. Right to deletion
4. Right to restriction of processing
5. Right to data portability
6. Right to object
7. Right to withdraw consent
8. Right to complain to a data protection authority

The account area should provide options to:

- Download personal data
- Edit profile data
- Delete the account
- Manage marketing preferences
- View active sessions
- View order and ticket history

Account deletion shall not remove data that must legally be retained. Such data shall be restricted, anonymized, or deleted when the legal retention period ends.

9. Email and Ticket Delivery

1. Order confirmation emails shall be sent only to the verified or checkout-provided email address.
 2. Emails shall not contain full payment information.
 3. Digital tickets shall be attached as protected PDF files or provided through a secure authenticated download link.
 4. Ticket download links shall be time-limited or require authentication.
 5. QR codes shall be unique and verifiable.
 6. A ticket shall not be accepted more than once unless explicitly revalidated.
 7. Ticket cancellation or refund shall invalidate the corresponding QR code.
 8. Email delivery failures shall be recorded without exposing sensitive information.
-

10. Logging and Auditing

The system shall create audit records for:

- Login and logout
- Failed login attempts
- Password changes
- Profile changes
- Payment status changes
- Order creation
- Refunds and cancellations
- Seat reservation and release
- Ticket generation
- Ticket scans
- Administrative access
- Data export and deletion requests

Logs shall:

- Use synchronized timestamps
 - Avoid storing passwords or payment secrets
 - Restrict access to authorized personnel
 - Be protected against unauthorized modification
 - Be monitored for suspicious activity
-

11. Backup and Recovery

1. Databases shall be backed up regularly.
2. Backups shall be encrypted.
3. Backup access shall be restricted.
4. Backup restoration shall be tested regularly.
5. The system shall define:
 - Recovery Point Objective (RPO)
 - Recovery Time Objective (RTO)
6. Backups shall follow the same retention and deletion requirements as production data.
7. Deleted personal data shall not remain indefinitely in accessible backups.

Example targets:

- RPO: maximum 15 minutes of data loss
 - RTO: service restored within 60 minutes after a critical failure
-

12. Data Processing by Third Parties

The system may use external processors for:

- Payment processing
- Email delivery
- PDF generation
- QR-code generation
- Cloud hosting
- Monitoring and error tracking
- Customer support

For every processor, the operator shall document:

- Processing purpose
- Data categories transferred
- Storage location
- Security measures
- Retention period
- Data processing agreement
- International data transfer safeguards

Third parties shall receive only the data necessary for their specific service.

13. Performance and Scalability Requirements

The data layer shall support:

- Up to 10,000 events
- Up to 1,000,000 user profiles
- At least 500 simultaneous checkout transactions per second
- Concurrent seat reservations without overbooking
- Efficient search by artist, venue, and city
- Fast retrieval of order history and available tickets

The database should use:

- Indexed event search fields
 - Indexed user email addresses
 - Indexed order and ticket IDs
 - Indexed seat and event relationships
 - Efficient pagination
 - Connection pooling
 - Caching for event listings
 - Queue-based processing for emails and PDF generation
-

14. Data Validation and Business Rules

The system shall enforce the following rules:

1. A user cannot purchase an unavailable seat.
 2. A user cannot reserve the same seat twice in the same active cart.
 3. A reservation expires after ten minutes.
 4. An expired reservation cannot be paid for.
 5. An order cannot be marked as paid without confirmed payment-provider feedback.
 6. A ticket cannot be generated for a failed or cancelled order.
 7. A cancelled or refunded ticket cannot be scanned successfully.
 8. The total order amount shall be calculated server-side.
 9. Prices shown to the user shall be revalidated during checkout.
 10. Ticket quantities shall match the number of selected seats.
 11. A QR code shall refer to exactly one valid ticket.
 12. Payment retries shall not create duplicate orders or duplicate charges.
-

15. Current Demo Application Limitation

The current static frontend stores demo cart and order data in browser `localStorage`. This is suitable only for prototyping and does not meet production requirements for:

- Secure authentication
- GDPR-compliant central data storage
- Concurrent seat locking
- PCI-DSS payment processing
- Reliable order persistence
- Real email delivery
- PDF ticket generation
- Cryptographically secure QR validation
- Multi-user consistency

For production, the frontend would require a backend API, transactional database, authentication service, payment provider, email service, ticket/PDF service, and centralized audit logging.

→ Functional requirements:

1. The system shall allow users to register, log in, and manage their personal account details
2. The system shall provide a global search bar on the top navigation menu that searches concerts by artist name, venue
3. The system shall provide a top navigation menu to filter events by music genre (e.g., Rock, Pop, Electronic, Jazz).
4. Users should be able to sort the displayed events alphabetically by act name or chronologically by event date.
5. Each event should be presented as a card displaying a picture, act name, date, location and genre badge.
6. Tickets should be able to be added directly to the shopping cart without forcing the user into the detail view.
7. Upon adding tickets to the shopping cart, the system shall temporarily lock those specific seats for 10 minutes to prevent double-booking.
8. The user should be able to adjust tickets quantity directly on the event card (e.g. via dropdown) for fast check out
9. The user should have the possibility to open and use an interactive venue seating chart for selected tickets (choose where to seat, see pricing and availability)
10. Clicking on an event the respective card should open in an expanded detail view containing additional event information and tickets for purchase
11. Should a user not register, a streamline checkout process should allow users to complete their purchase by entering contact details and selecting a payment method.

12. The system shall generate a digital ticket containing a unique verifiable QR code for venue entrance scan.
13. The system shall automatically release locked tickets back into the public available inventory if the checkout process is not completed within 10 minutes.

→ **Non-functional requirements:**

1. The landing page and concert listing menu shall load completely in under 2 seconds on standard mobile and desktop networks.
2. The system shall maintain database consistency and zero overbooking errors
3. The user interface shall comply with web accessibility standards
4. The user interface is self-explanatory, enabling first-time visitors to complete a ticket purchase without prior instruction.
5. The application adapts fluidly across different screen sizes (desktop, tablet, and mobile devices).

→ **Algorithm description - AI**

Search Events

Read the user's search input and filter concerts by artist, venue

Select Tickets

Display the selected event's seating chart. Allow the user to select available seats and add them to the cart.

Reserve Seats

When tickets are added to the cart, verify that the seats are still available and reserve them for 10 minutes.

Run Countdown

Start a countdown timer for the reservation. If the timer expires before payment, release the seats and remove the tickets from the cart.

Checkout and Payment

Revalidate the seats and total price, then submit the payment through the selected payment provider.

Create Tickets

If payment succeeds, create a unique order and digital ticket for each seat, including a verifiable QR code.

Send Confirmation

Send the customer an order confirmation email with the digital ticket PDF attached or available for secure download.

Manage Orders

Store the order in the user's account so past and upcoming tickets can be viewed and downloaded.

Simplified Overall Pseudocode -AI

START

User searches for an event

IF matching events exist: Display matching events ELSE: Display "No events found"

User selects an event Load event details and current seat availability

User selects seats

IF selected seats are available: Begin transaction

Lock selected seats

Create reservation with 10-minute expiration

IF transaction succeeds:

 Add tickets to cart

 Start countdown

ELSE:

 Display reservation error

ELSE: Display "Some seats are no longer available"

WHILE cart contains tickets: Display cart and remaining reservation time

IF reservation expires:

 Release seats

 Empty cart

 Stop checkout

IF user starts checkout:

 Revalidate seats, prices, and reservation

 IF validation fails:

Display checkout error
ELSE:
Send payment request

IF payment fails:
Release or retain reservation according to policy
Display payment error
ELSE:
Begin transaction

Create order
Mark seats as sold
Create digital tickets
Generate QR codes and PDF files
Mark reservation as completed

Commit transaction
Send confirmation email
Display successful order message

END